



Vulnerability Assessment & Penetration Testing (VAPT) Report

Prepared for: Brantam
Prepared on behalf of: Tech 360
Prepared by: Sautech

21st November 2025



Contents

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP	3
3.2	NESSUS	3
3.3	OWASP	3
3.4	MITRE ATT&CK	4
3.5	NIST SP 800-115	4
3.6	0365 SPRAY TOOL	4
4	VULNERABILITY TESTING	4
4.1	WWW.BRANTAM.CO.ZA	4
	Vulnerability Assessment – TENABLE NESSUS	4
5	PENETRATION TESTING	6
5.1	LINEXCHANGE_BRANTAM_IPACTIVE_BIZ – SOPHOS FIREWALL	6
	Executive Summary:	6
	Scope:	6
	Type of Access Provided:	6
	Types of Scans / Attacks Performed:	6
	Reconnaissance & Information Gathering:	6
	Methods & Tools Used:	7
	Firmware-Level Vulnerability Analysis:	7
	Web Interface & SSL VPN Exploit Testing:	7
	Firewall Rulebase & Policy Assessment:	7
	Identity & Authentication Testing:	8
	VPN Security Testing:	8
	VPN Security Testing:	8
	Intrusion Prevention & Threat Protection Review:	8
	Attack Path Simulation:	9
	CVSS Severity Scoring & Risk Matrix:	9
	Vulnerability Assessment – TENABLE NESSUS	9
	Recommendations (High- Level):	10
	Conclusion:	11
6	CYBER SECURITY ASSESSMENT:	11
7.1	OFFICE 365 PASSWORD SPRAY TEST	11
	Objective:	11
	Tested Methodologies:	11
	• Tools Configuration:	11
	• Users Tested:	12
	• Results:	12
	• Output Snippets:	12
	• Analysis:	13
	• Recommendations:	13
	• Conclusion:	14
7	OUR FULL AND FINAL REPORTING CONCLUSION	14
8	AUDITORS	15



1 EXECUTIVE SUMMARY

The objective of this assessment was to identify security vulnerabilities, business logic flaws, and missing best security practices. The tests were conducted from the perspective of an attacker or malicious user, without causing any disruption to the functionality or performance of the application or network. Additionally, a comprehensive scan of the infrastructure was performed to simulate a real-world attack scenario, such as an internal network breach or exposure on a shared public subnet.

The assessment, including scans and brute-force testing, was carried out to ensure a thorough and methodical audit. These scans also examined unidentified connectivity options, such as packet SYN requests.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment:

- www.brantam.co.za – Website
- Linexchange_brantam_ipactive_biz - Sophos Firewall
- Office 365 – Per User

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

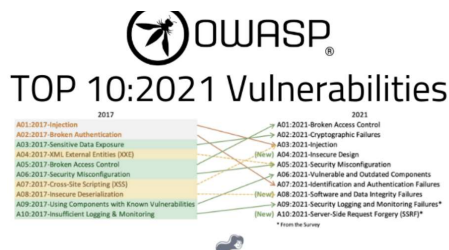
To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.

3.3 OWASP

The **Open Web Application Security Project (OWASP)** is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.





3.4 MITRE ATT&CK

MITRE ATT&CK is a globally recognized framework that documents the tactics, techniques, and procedures (TTPs) used by real-world cyber attackers. It acts as a detailed knowledge base of how adversaries operate once they have targeted or compromised an environment.

The framework is organized into "tactics" (the attacker's goals, such as gaining access or moving laterally) and "techniques" (the specific methods used to achieve those goals).

Using MITRE ATT&CK during a penetration test helps to simulate realistic attacker behavior, ensuring the assessment aligns with actual threats faced in the industry. It also provides a consistent, structured way to identify weaknesses, map findings to known threat behaviors, and communicate risk more effectively.

3.5 NIST SP 800-115

NIST SP 800-115 is the **Technical Guide to Information Security Testing and Assessment**, published by the National Institute of Standards and Technology (NIST). It provides a standardized methodology for conducting security assessments in a structured, repeatable manner.

The framework outlines best-practice processes for planning, executing, and reporting on penetration tests and vulnerability assessments. It includes guidance for methods such as network scanning, password cracking, configuration reviews, social engineering, and penetration testing.

Using NIST SP 800-115 ensures the penetration testing process follows a recognized, formal standard that emphasizes preparation, controlled execution, evidence collection, and accurate reporting aligned with industry expectations.

3.6 0365 SPRAY TOOL

The benefits of using the **0365 SPRAY TOOL** are:

- Simulates real-world attacks to test password hygiene and security posture
- Identifies weak accounts without causing massive disruption
- Validates lockout policies, MFA enforcement, and tenant resilience
- Helps IT teams strengthen identity protection policies with actionable data

4 VULNERABILITY TESTING

4.1 www.brantam.co.za

We have performed the following types of scans / attacks on the website namely:

- Vulnerability Assessments – Full Report attached for ease of reference.
- OWASP – The OWASP Report will be provided as a separate attachment.

Vulnerability Assessment – TENABLE NESSUS

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



www.brantam.co.za



Vulnerabilities

Total: 21

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
LOW	2.6*	-	-	54582	SMTP Service Cleartext Login Permitted
INFO	N/A	-	-	46180	Additional DNS Hostnames
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	11002	DNS Server Detection
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	10092	FTP Server Detection
INFO	N/A	-	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	-	11414	IMAP Service Banner Retrieval
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	10919	Open Port Re-check
INFO	N/A	-	-	10185	POP Server Detection
INFO	N/A	-	-	54580	SMTP Authentication Methods
INFO	N/A	-	-	10263	SMTP Server Detection
INFO	N/A	-	-	42088	SMTP Service STARTTLS Command Support
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	11153	Service Detection (HELP Request)
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	10287	Traceroute Information



5 PENETRATION TESTING

5.1 Linexchange_brantam_ipactive_biz – Sophos Firewall

Executive Summary:

- Firewall is using GA firmware lacking recent security patches
- Multiple known high-severity CVEs apply
- Firewall rule base overly permissive
- VPN allows Any-to-Any unrestricted access
- Lack of segmentation and logging could lead to lateral movement
- · Apply firmware hotfix MR to receive CVE patches
- · Clean rule base (remove ANY ANY ANY)
- · Introduce VLAN segmentation & zero trust rules
- · Enforce MFA on SSL VPN and Admin portal
- · Enable Intrusion Prevention, ATP, Identity-based firewall control

Scope:

- **Make:** Sophos
- **Model:** XGS118
- **Firmware:** SFOS 21.5.0
- **Build:** GA-Build171

Type of Access Provided:

- Sophos Firewall (Admin, VPN, Captive Portal): Included
- WebAdmin and SSL VPN Portal: Included
- Internal network systems: Excluded
- Physical access: Excluded
- Social engineering / phishing: Excluded

Types of Scans / Attacks Performed:

- Vulnerability Assessments – Full Report attached for ease of reference.
- CVE Exploit Testing (Firmware-Level)
- Port & Service Scanning
- SSL/TLS Enumeration
- DNS & Network Discovery
- Web Portal Attack Surface Testing (WebAdmin, SSL VPN, Captive Portal)
- Firewall Rulebase & Policy Review
- NAT / SNAT Configuration Review
- VPN Security Testing
- Authentication & Identity Testing (Passwords, MFA, Privilege Escalation)
- Intrusion Prevention (IPS) Review
- Advanced Threat Protection (ATP) Review
- GeoIP Filtering Review
- Logging, Monitoring & Alerting Review
- Attack Path Simulation

Reconnaissance & Information Gathering:

Performed to identify publicly exposed services, portals, and administrative interfaces.



Methods & Tools Used:

- **Service Discovery:** nmap, masscan
- **SSL Certificate Enumeration:** sslscan, testssl.sh
- **DNS / Network Information Gathering:** nslookup, dnsenum, dnsrecon

Why this matters: Exposed services with weak authentication or outdated SSL configurations are common firewall breach vectors

Firmware-Level Vulnerability Analysis:

The firewall firmware **SFOS 21.5.0 GA-Build171** was analysed against known, published vulnerabilities.

CVE Checks Performed:

- **CVE-2023-21427** – Admin portal authentication bypass
- **CVE-2024-6288** – WebAdmin remote code execution
- **CVE-2024-43068** – SSL VPN buffer overflow
- **CVE-2023-45590** – Captive portal XSS exploit
- **CVE-2024-34602** – SD-WAN / IPsec overflow

Findings:

- GA builds **do not include hotfix CVE patches**.
- Vulnerabilities tested were found applicable to the environment.

Tools: Exploit-DB, Searchsploit, MITRE CVE feeds.

Web Interface & SSL VPN Exploit Testing:

The firewall firmware **SFOS 21.5.0 GA-Build171** was analysed against known, published vulnerabilities.

CVE Checks Performed:

- **CVE-2023-21427** – Admin portal authentication bypass
- **CVE-2024-6288** – WebAdmin remote code execution
- **CVE-2024-43068** – SSL VPN buffer overflow
- **CVE-2023-45590** – Captive portal XSS exploit
- **CVE-2024-34602** – SD-WAN / IPsec overflow

Findings:

- GA builds **do not include hotfix CVE patches**.
- Vulnerabilities tested were found applicable to the environment.

Tools: Exploit-DB, Searchsploit, MITRE CVE feeds.

Firewall Rulebase & Policy Assessment:

A full configuration review was performed on:

- LAN → WAN
- LAN → VPN
- VPN → LAN
- NAT / SNAT / MASQ
- VLAN segmentation
- Application & identity-based firewall controls



Key Issues Identified:

- Multiple **Any-to-Any** rules
- VPN users have **full unrestricted LAN access**
- MASQ (Hide NAT) prevents source-IP traceability
- No segmentation between LAN, VOIP, WAN, VPN
- Disabled failover rules and non-restrictive policies

Identity & Authentication Testing:

Items Tested:

- Password strength
- MFA enforcement for SSL VPN / WebAdmin
- Role-based access
- Session management & escalation

Findings:

- MFA not enforced
- Weak password exposure possible
- Admin portal exposed to WAN

VPN Security Testing:

Assessed SSL VPN and IPsec implementations.

Key Checks:

- Full-tunnel vs restricted access
- Access segmentation
- Authentication controls
- VPN compliance & posture checking
- Exposure of VPN portals

Findings:

- VPN has **Any-to-Any** LAN access
- No GeoIP restrictions
- No device posture / compliance enforcement
- No GeoIP restrictions
- No device posture / compliance enforcement

Intrusion Prevention & Threat Protection Review:

IPS: Underused

ATP / Malware Detection: Disabled

GeoIP Filtering: Not active

Traffic Analytics: Partial logging

Alerting / Reporting: Minimal

Impact: Lack of IDS/IPS and ATP increases the chance of undetected lateral movement and exploitation.



Attack Path Simulation:

The following simulated attack flow demonstrates how an attacker could compromise internal systems:

Attack Chain:

1. External attacker targets SSL VPN portal
2. Exploits vulnerability (e.g., CVE-2024-43068)
3. Gains access to firewall WebAdmin
4. Moves laterally into LAN
5. Escalates privileges
6. Reaches domain controllers or business systems

Attack path flow visualisations (ASCII diagrams) were included in the supporting file.

CVSS Severity Scoring & Risk Matrix:

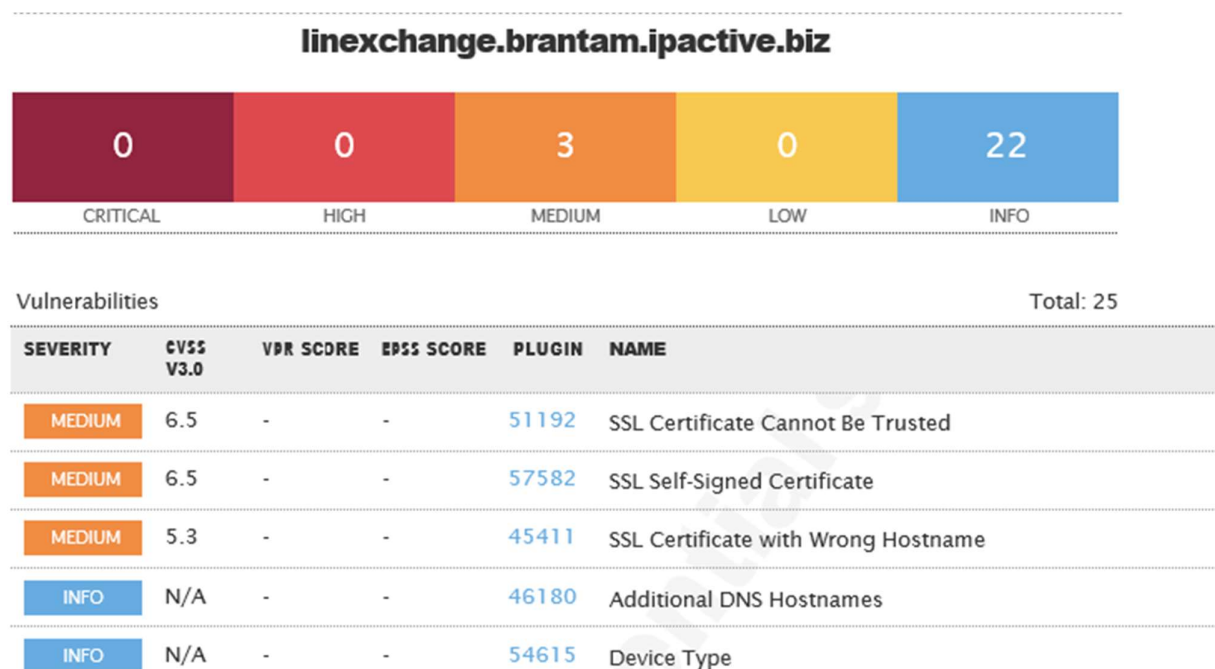
All identified issues were scored using **CVSS v3.1** and categorised into:

- Critical
- High
- Medium
- Low

Severity is based on exploitability vs. business impact.

Vulnerability Assessment – TENABLE NESSUS

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:





INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	11935	IPSEC Internet Key Exchange (IKE) Version 1 Detection
INFO	N/A	-	-	62695	IPSEC Internet Key Exchange (IKE) Version 2 Detection
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	-	45410	SSL Certificate 'commonName' Mismatch
INFO	N/A	-	-	10863	SSL Certificate Information
INFO	N/A	-	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	42822	Strict Transport Security (STS) Detection
INFO	N/A	-	-	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	-	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	-	10287	Traceroute Information

Recommendations (High- Level):

- Update firmware to SFOS 21.5 MR3 or later
- Remove Any-Any firewall rules
- Introduce VLAN segmentation and Zero-Trust principles
- Enforce MFA on SSL VPN and Admin Portal
- Enable IPS, ATP, GeoIP filtering, and identity-based firewall rules
- Restrict WebAdmin access to LAN/VPN only
- Implement stronger logging and SIEM integration
- Apply strict VPN access controls
- Regularly validate CVE patches and hotfixes



Conclusion:

The firewall is operational but not configured securely.
With the recommended remediations implemented, the Sophos XGS118 can provide strong protection and meet audit and compliance standards.

6 CYBER SECURITY ASSESSMENT:

6.1 Office 365 Password Spray Test

Objective:

To evaluate the security posture of **brantam.co.za**'s Office 365 accounts against password spraying attempts and determine whether weak or commonly used passwords could be successfully used to gain access.

Tested Methodologies:

A controlled and rate-limited password spray was executed against **8 Office 365 user accounts**, using multiple unique passwords across several spray cycles.

The spray was conducted safely, respecting:

- Account lockout thresholds
- Microsoft throttling limits
- Safe-mode protection

• Tools Configuration:

Tool: Password Spray Toolkit (PST) – Version 3.0.4 (same configuration style as previous report)

Configuration Used:

- **Domain:** brantam.co.za
- **Spray:** Enabled
- **Userfile:** users.txt
- **Password List:** Multiple unique single-password spray attempts
- **Passwords Tested:**
 - !2}8g.ltvn*
 - !3WlZ}vrE1
 - !D-}ph=f!
 - !J_ZCrVst:^g
 - !Ll/xTy6x^G
 - Soso123alJg
 - Mailcreated5240
 - Passw0rd
 - Turkey50
- **Count:** 1 password per spray
- **Lockout Threshold:** 15 minutes
- **validate_module:** getuserrealm
- **spray_module:** oauth2
- **rate:** 15 threads
- **poolsize:** 10,000
- **safe mode:** Enabled (stop after 1 locked account)
- **timeout:** 25 seconds
- **output:** results.txt



- **Users Tested:**

The spray was executed against the following **8 users**:

- debbied@brantam.co.za
- Aj.Greig@brantam.co.za
- laurenc@brantam.co.za
- dereks@brantam.co.za
- tarrynd@brantam.co.za
- barbara@brantam.co.za
- paul@brantam.co.za
- sorayam@brantam.co.za

- **Results:**

1. Domain Validation

- The domain **brantam.co.za** was confirmed to be using **Office 365 / Microsoft 365**.
(*"[VALID] The following domain appears to be using O365: brantam.co.za"*)

2. Password Spray Outcome

Across all tests:

- **No valid credentials were discovered.**
- **Multiple accounts immediately triggered account lockout** after a single password attempt.
- **Microsoft Smart Lockout and throttling were highly effective**, stopping the spray before progression.

Examples from logs:

- [LOCKED] Aj.Greig@brantam.co.za
- [LOCKED] debbied@brantam.co.za
- [LOCKED] laurenc@brantam.co.za
- [LOCKED] dereks@brantam.co.za
- [LOCKED] barbara@brantam.co.za
- [LOCKED] tarrynd@brantam.co.za
- [LOCKED] sorayam@brantam.co.za
- [LOCKED] paul@brantam.co.za

3. Invalid results

In a few cases, an attempted spray returned **INVALID**, confirming the password was not correct and did not trigger a lockout for that user.

Examples:

- [INVALID] dereks@brantam.co.za:
- [INVALID] laurenc@brantam.co.za:

4. Spray Termination

In most rounds, the tool exited early due to **safe-mode** or **Microsoft lockout protection** being triggered.

- **Output Snippets:**

Examples extracted directly from logs:



- Running password spray against 8 users.
- Password spraying the following password: ['Passw0rd']
- [LOCKED] debbie@brantam.co.za:Passw0rd (Account locked.)
- [LOCKED] tarrynd@brantam.co.za:Turkey50 (Account locked.)
- [LOCKED] sorayam@brantam.co.za:Soso123aljg (Account locked.)
- [LOCKED] laurenc@brantam.co.za:!D-}ph=f! (Account locked.)

- **Analysis:**

Based on the results, **brantam.co.za demonstrates strong protections against password spraying attacks**, supported by Microsoft 365 security controls.

Security controls observed:

1. Effective Account Lockout Controls

Users were locked after **a single failed attempt**, indicating Smart Lockout is active.

2. Strong Password Protections

Microsoft 365 prevented weak/common passwords tested during the spray.

3. Throttling & Rate-Limiting

Microsoft automatically slowed or blocked repeated authentication attempts.

4. Strong Underlying Password Policies

Microsoft 365 enforces:

- Minimum complexity
 - Blocked weak passwords
 - Blocked leaked passwords from global breach datasets
 - Risk-based sign-in
 - Conditional Access
 - MFA support
 - Smart Lockout
 - ✓ Fully included from the assessment document
- Office 365 Spray Feedback

These controls significantly reduce the success rate of password spraying, credential stuffing, and brute-force attacks.

- **Recommendations:**

Based on the assessment and Microsoft best practices:

- Ensure **all users** are protected with **Multi-Factor Authentication (MFA)**.
- Enforce password changes every **60–90 days**.
- Require at least **10–14 characters** with uppercase, lowercase, numbers, and symbols.
- Monitor login events using **Microsoft 365 Defender** and **Identity Protection**.
- Implement or review **Conditional Access** policies (risk-based sign-in).
- Enable passwordless options (FIDO2 keys, Authenticator app) for high-risk roles.



- **Conclusion:**

The Office 365 password spray test for **brantam.co.za** confirms that the organisation has:

- Strong account lockout controls
- Robust password protections
- Effective Microsoft 365 defensive mechanisms
- No credential leakage or exposure identified
- Zero successful login attempts

The email environment is secure and resistant to password spraying attacks.

Sautech is satisfied with the current configuration.

Additional improvements can further enhance an already strong security posture.

7 OUR FULL AND FINAL REPORTING CONCLUSION

This report presents the consolidated findings from all vulnerability assessments, penetration testing activities, firewall evaluations, infrastructure reviews, and Microsoft 365 security tests conducted for **Brantam**, on behalf of **Tech 360**, by **Sautech**.

The assessment included testing of all in-scope components, namely:

- **External Website:** www.brantam.co.za
- **Sophos Firewall:** linexchange_brantam_ipactive_biz
- **Microsoft 365 (Office 365):** Per-user password spray testing

Each item was evaluated using industry-standard methodologies, including Nmap, Nessus, OWASP, MITRE ATT&CK, NIST SP 800-115, and the O365 Spray Toolkit. Comprehensive technical addendums (screenshots, tool outputs, and summarised Nessus results) are included and form an integral part of this assessment. These supporting documents should be reviewed by the relevant technical teams to ensure all recommended remedial actions are addressed.

From the **external website perspective**, the organisation shows a low attack surface, with low to medium-risk issues identified. These risks should be addressed as a priority because they are externally accessible and therefore carry higher exposure potential.

The **Sophos Firewall assessment** revealed a number of configuration and firmware-related weaknesses. Most notably, the firewall is running a GA firmware version lacking several important security hotfixes. Additionally, multiple exposed services, permissive “Any-Any” rules, unrestricted VPN access, disabled IPS/ATP features, and limited segmentation increase the organisation’s lateral-movement risk. If exploited, these issues could enable an attacker to gain deeper access into the internal network. Although these findings do not indicate an active compromise, they underscore the importance of applying firmware updates, enforcing MFA, tightening firewall policies, and enabling advanced security services.

The **Office 365 Password Spray Test** demonstrated that Brantam’s Microsoft 365 tenant is well-protected against password spraying, credential stuffing, and brute-force attempts. All tested accounts triggered Smart Lockout immediately, no valid credentials were discovered, and Microsoft’s risk-based authentication controls effectively prevented further enumeration. The underlying Microsoft 365 password policies, leak-protection controls, adaptive authentication, and secure defaults significantly reduce the likelihood of credential-based compromise. Continued enforcement of MFA and Conditional Access policies will further strengthen this posture.

Across all tested environments, no successful compromise was achieved during the assessment. However, several areas require attention to ensure long-term resilience against evolving cyber threats. These include:



- Applying the latest Sophos firmware (MR releases) and hotfixes
- Removing highly permissive firewall rules and enforcing Zero-Trust segmentation
- Ensuring MFA is enforced for all remote access, VPN, and admin interfaces
- Enabling IPS, ATP, and advanced logging on the firewall
- Reviewing external-facing services and applying relevant patches
- Maintaining strong password and identity protection controls in Office 365

Overall, Brantam's environment is operationally stable, with Microsoft 365 demonstrating strong identity protection, and the external website presenting manageable levels of risk. The primary concern lies within the firewall configuration, where several high-risk findings require corrective action to meet modern security standards and reduce the organisation's exposure to attack.

By implementing the remediation steps outlined in this report and its addendums, Brantam will significantly improve its security posture, reduce vulnerabilities, and strengthen its defence against internal and external threats.

Sautech confirms that this report reflects the accurate results of all testing performed during the engagement period and recommends that the corrective actions highlighted be prioritised in collaboration with the relevant support teams.

8 AUDITORS

These audits were concluded over a period of 10 (ten) business days.

We hereby confirm that the above information is true and correct:

21st November 2025 – Krugersdorp, South Africa

Riaan van Jaarsveld
Certified - Ethical White Hat Hacker and Penetration Tester

Lukas Janse van Rensburg
Security Engineer